



Timing Oracle



Bối cảnh (Context)

Một tổ chức tội phạm đã tạo ra một chiếc hộp an toàn kỹ thuật số. Khi bạn nhập một đoạn mật khẩu 20 ký tự, máy chủ sẽ so sánh từng chữ cái một với mật khẩu thật. Nếu chữ cái đầu tiên sai, nó ngay lập tức báo "Sai". Nếu chữ cái đầu tiên đúng, nó mới kiểm tra tiếp chữ cái thứ hai.

Điều này giúp máy chủ chạy rất nhanh, nhưng một chuyên gia phân tích dữ liệu đã nhận ra sự khác biệt vi tế về thời gian phản hồi của máy chủ trong mỗi lần nhập.



Mục tiêu (Objective)

- **Nhiệm vụ:** Lấy được mật khẩu 20 ký tự (Flag) mà không cần phải biết trước nó là gì, thông qua việc phân tích thời gian.
- **Vấn đề / Lỗ hổng: Timing Attack.** Hàm so sánh chuỗi không chạy trong thời gian hằng định (Constant-time). Khi đoán đúng 1 ký tự, thời gian phản hồi của server sẽ lâu hơn một chút (vài mili-giây) so với khi đoán sai, vì server phải mất công kiểm tra ký tự tiếp theo. Kẻ tấn công có thể đo thời gian để mò ra từng ký tự một.
- **Flag:** Mật khẩu bí mật đóng vai trò là Flag.



Gợi ý (Hints)

- Bạn chắc chắn phải viết một script Python tự động.
- Dùng module `requests` và xem xét thuộc tính `r.elapsed.total_seconds()` để lấy thời gian phản hồi.
- Lặp qua các ký tự, ký tự nào làm thời gian phản hồi dài nhất thì đó là ký tự đúng.